Université Sultan Moulay Slimane
École Nationale des Sciences Appliquées
Béni Mellal

Rapport de Projet de Fin d'Année

Filière :
Cybersécurité et Intelligence Artificielle

Sous le thème :

Plateforme d'auto-évaluation de la maturité cybersécurité pour les PME

Réalisé par :

Youssef Ait Karroum

Encadré par :

Dr. Rachid Abouettahir (CMRPI – Espace Maroc Cyberconfiance)

Soutenu le 11/11/2026 devant le jury composé de :

Membre	Établissement	Qualité
Pr. Mohamed Gouskir	ENSA Béni Mellal	Membre du jury
Pr. Wissal Fartit	ENSA Béni Mellal	Membre du jury

Année universitaire : 2025–2026

Avant-propos

Ce rapport constitue le mémoire du stage de Projet de Fin d'Année (PFA) réalisé dans le cadre de la formation d'Ingénieur d'État en **Intelligence Artificielle et Cybersécurité (IACS)** à l'École Nationale des Sciences Appliquées de Béni Mellal (ENSA-BM), rattachée à l'Université Sultan Moulay Slimane.

Le stage s'est déroulé au sein du **Centre Marocain de Recherches Polytechniques et d'Innovation (CMRPI)**, dans le cadre de son initiative Espace Maroc Cyberconfiance, durant la période allant du **15 juillet 2026** au **31 août 2026**, sous la supervision du Dr. Rachid Abouettahir (encadrant professionnel, CMRPI).

Résumé

Les petites et moyennes entreprises (PME) marocaines ne disposent pas, à ce jour, d'un outil simple et accessible pour évaluer leur propre niveau de maturité en cybersécurité. Le Centre Marocain de Recherches Polytechniques et d'Innovation (CMRPI), à travers son initiative Espace Maroc Cyberconfiance, dispose d'un référentiel de bonnes pratiques élaboré avec l'Association des Utilisateurs des Systèmes d'Information au Maroc (AUSIM), mais celui-ci reste un document statique non opérationnalisé sous forme d'outil d'auto-diagnostic. Ce stage de Projet de Fin d'Année, réalisé sur sept semaines au sein du CMRPI, a eu pour objectif de concevoir et développer une plateforme d'auto-évaluation répondant à ce besoin.

La méthodologie retenue s'appuie sur une analyse croisée du guide CMRPI/AUSIM, de la norme ISO/IEC 27001, du NIST Cybersecurity Framework et de la loi 09-08, aboutissant à un questionnaire structuré en cinq domaines de cinq questions chacun, dont la structure est justifiée académiquement par le modèle de maturité CMM/CMMI et les travaux de Dawes sur les échelles de Likert, complétés par une décision de conception assumée sur le nombre de questions par domaine. Un moteur de scoring calcule automatiquement un score par domaine et un score global sur une échelle de 0 à 100, interprété selon quatre niveaux de maturité, et génère deux à trois recommandations priorisées selon les domaines les plus faibles.

Un premier prototype développé avec Streamlit a permis de valider le moteur et le parcours auprès de l'encadrant. La plateforme finale, baptisée **Pentascore**, repose sur une interface React (TypeScript), une API FastAPI qui recalcule toujours le score côté serveur, un moteur métier Python indépendant de l'interface et une base SQLite. Elle fonctionne entièrement hors ligne et ajoute au score : le détail des points perdus, 30 règles de cohérence qui signalent les réponses contradictoires, un rapport PDF de trois pages avec QR code de réévaluation, un badge partageable, un historique des évaluations et un compte facultatif conforme à la loi 09-08. La qualité logicielle est validée par 285 tests côté serveur, 71 tests côté interface et 13 parcours de bout en bout, avec 98 % de couverture de code et une intégration continue.

La plateforme livrée est fonctionnelle de bout en bout et a été validée par l'encadrant professionnel. Ses principales limites – une évaluation déclarative, une validation limitée à des profils fictifs, des poids et des seuils fixes – ouvrent la voie à un pilote avec de vraies PME, à une évaluation accompagnée par le CMRPI et à un déploiement en ligne.

Mots-clés : Cybersécurité, Auto-évaluation, Maturité, PME, ISO 27001, NIST Cybersecurity Framework, React, FastAPI

ملخص

لا تتوفر الشركات الصغيرة والمتوسطة المغربية، حتى الآن، على أداة بسيطة وسهلة الاستخدام لتقييم مستوى نضجها في مجال الأمن السيبراني. ويملك المركز المغربي للأبحاث البوليتكنيكية والابتكار (CMRPI)، من خلال مبادرة الفضاء المغربي للثقة الرقمية (EMC)، دليلاً للممارسات الجيدة أُعدّ بالتعاون مع جمعية مستخدمي أنظمة المعلومات بالمغرب (AUSIM)، إلا أن هذا الدليل يبقى وثيقة ثابتة لم يتم تفعيلها في شكل **أداة للتشخيص الذاتي**. يهدف هذا التدريب الأكاديمي (مشروع نهاية السنة)، المنجز على مدى سبعة أسابيع داخل المركز المغربي للأبحاث البوليتكنيكية والابتكار، إلى تصميم وتطوير **منصة للتقييم الذاتي** تستجيب لهذه الحاجة.

تعتمد المنهجية المتبعة على **تحليل متقاطع** لدليل CMRPI/AUSIM، ومعيار ISO 27001، وإطار العمل NIST للأمن السيبراني، والقانون رقم 09-08، ليتم التوصل إلى استبيان مُهيكل في خمسة مجالات، يضم كل منها خمسة أسئلة، تُبرَّر بنيته أكاديمياً **بنموذج النضج CMM/CMMI**، وأعمال Dawes حول مقاييس Likert، والقاعدة الاسترشادية لعدد الأسئلة. يقوم **محرك حساب النقاط** تلقائياً بحساب نقطة لكل مجال ونقطة إجمالية على مقياس من صفر إلى مائة، تُفسَّر وفق أربعة مستويات من النضج، ويولّد من اثنتين إلى ثلاث توصيات ذات أولوية حسب المجالات الأضعف.

طُوّرت المنصة بلغة Python باستخدام إطار العمل Streamlit للواجهة، وقاعدة بيانات SQLite لتخزين البيانات، ومكتبة ReportLab لتصدير التقارير بصيغة PDF. وتوفر المنصة **نمطين لعرض الاستبيان**، ونظام تصميم بألوان المركز المغربي للأبحاث البوليتكنيكية والابتكار يتضمن **مخططاً شعاعياً لنقط المجالات**، إضافة إلى ثلاثة نماذج افتراضية لشركات صغيرة ومتوسطة تتيح تجربة فورية للمنصة. وقد تم التحقق من جودة البرمجيات من خلال 52 اختباراً آلياً، ونسبة تغطية للشيفرة البرمجية بلغت 90 بالمئة، وسلسلة تكامل مستمر.

في ختام فترة التدريب، تم تسليم منصة وظيفية متكاملة تمت المصادقة عليها في كل مرحلة من طرف المشرف المهني. وتفتح أبرز القيود المرصودة — النطاق أحادي المستخدم، وقاعدة بيانات غير ملائمة لزيادة عدد المستخدمين، وعدم إتمام النشر عبر الإنترنت بعد — آفاقاً للتطور نحو **بنية إنتاجية متعددة المستخدمين**.

الكلمات المفتاحية: الأمن السيبراني، التقييم الذاتي، النضج، الشركات الصغيرة والمتوسطة، معيار ISO 27001 ، إطار العمل NIST للأمن السيبراني، Streamlit.

Abstract

Moroccan small and medium-sized enterprises (SMEs) currently lack a simple and accessible tool to assess their own level of cybersecurity maturity. The Moroccan Center for Polytechnic Research and Innovation (CMRPI), through its Espace Maroc Cyberconfiance initiative, maintains a best-practices guide developed with AUSIM, but this guide remains a static document that has not been operationalized as a self-assessment tool. This seven-week end-of-year internship, carried out within CMRPI, aimed to design and develop a self-assessment platform addressing this need.

The methodology relies on a cross-analysis of the CMRPI/AUSIM guide, the ISO/IEC 27001 standard, the NIST Cybersecurity Framework, and Moroccan law 09-08, resulting in a questionnaire structured around five domains of five questions each. This structure is academically justified by the CMM/CMMI maturity model and Dawes' research on Likert scale design, complemented by a deliberate design decision on the number of questions per domain. A scoring engine automatically computes a per-domain and a global score on a 0-100 scale, interpreted through four maturity levels, and generates two to three prioritized recommendations targeting the weakest domains.

A first Streamlit prototype was used to validate the scoring engine and the user journey with the supervisor. The final platform, named **Pentascore**, combines a React (TypeScript) interface, a FastAPI API that always recomputes the score on the server, a Python business engine independent of the interface, and a SQLite database. It runs fully offline and adds to the score : a breakdown of lost points, 30 consistency rules flagging contradictory answers, a three-page PDF report with a reassessment QR code, a shareable badge, an assessment history, and an optional account compliant with law 09-08. Software quality is backed by 285 server tests, 71 interface tests and 13 end-to-end journeys, with 98% code coverage and continuous integration.

The delivered platform works end to end and was validated by the professional supervisor. Its main limitations – a declarative assessment, validation on fictitious profiles only, fixed weights and thresholds – lead to a pilot with real SMEs, a CMRPI-assisted assessment and an online deployment.

Keywords : Cybersecurity, Self-assessment, Maturity, SME, ISO 27001, NIST Cybersecurity Framework, React, FastAPI

Dédicace

À mes parents,

Je dédie ce travail à mes parents, pour leur soutien indéfectible, leur patience inestimable et leurs encouragements constants tout au long de mon parcours académique. Leur présence, leur confiance et leurs sacrifices ont été une source de motivation inépuisable qui m'a permis de persévérer dans les moments les plus exigeants de cette formation.

À mes enseignants,

Je dédie également ce travail à l'ensemble de mes enseignants qui, par leur dévouement, leur rigueur et leur passion pour la transmission du savoir, ont façonné ma manière de penser et de résoudre les problèmes. Leur engagement a été déterminant dans mon développement intellectuel et professionnel.

À mes amis et camarades,

À mes amis et camarades de promotion, avec qui j'ai partagé les défis, les doutes et les réussites de ces années d'études. Leur camaraderie, leurs conseils et leur bonne humeur ont rendu cette expérience encore plus enrichissante.

À toute personne qui croit en l'importance de la cybersécurité pour protéger les entreprises marocaines.

Remerciements

Avant tout développement sur ce travail, il me paraît opportun de commencer par adresser mes sincères remerciements à toutes les personnes qui ont contribué, de près ou de loin, à la réalisation de ce projet.

Mes remerciements s'adressent en particulier :

- Au Directeur de l'ENSA-BM, **Pr. Belaid BOUIKHALENE**, pour son engagement en faveur de la qualité de la formation dispensée au sein de l'établissement ;
- Au Directeur adjoint de l'ENSA-BM, **Pr. Soufiane BELHOUIDEG** ;
- Au Coordonnateur de la filière Intelligence Artificielle et Cybersécurité, **Pr. Mohamed GOUSKIR**, pour le suivi et l'organisation de ce stage de Projet de Fin d'Année ;
- À mon encadrant professionnel, **Dr. Rachid Abouettahir** (Centre Marocain de Recherches Polytechniques et d'Innovation (CMRPI)), pour sa disponibilité tout au long des sept semaines de stage, ses points de contrôle hebdomadaires et la confiance accordée à chaque jalon du projet ;
- À l'ensemble du corps professoral et administratif de l'ENSA Béni Mellal, pour la qualité de la formation reçue durant le cycle d'ingénieur ;
- Ainsi qu'à toutes les personnes ayant contribué, de près ou de loin, à la réalisation de ce travail.

Table des matières

Avant-propos i

Résumé ii

Résumé (arabe) iii

Abstract iv

Dédicace v

Remerciements vi

Liste des figures x

Liste des tableaux xi

Liste des algorithmes xii

Liste des abréviations xiii

Introduction générale 1

1 Contexte général et problématique 2

1.1 Présentation de l'organisme d'accueil 2

1.1.1 Historique et création du CMRPI 2

1.1.2 Formations cybersécurité du CMRPI 3

1.1.3 Espace Maroc Cyberconfiance (EMC) 3

1.1.4 Structure organisationnelle 4

1.2 Problématique et objectifs 5

1.2.1 Problématique 5

1.2.2 Objectifs du projet 5

1.2.3 Périmètre du projet 6

1.2.4 Cahier des charges 6

1.3 Planification du projet 6

2 État de l'art 8

2.1 Référentiels normatifs analysés 8

2.1.1 Guide CMRPI/AUSIM 8

2.1.2 ISO/IEC 27001 :2022 . . . 8
2.1.3 NIST Cybersecurity Framework 2.0 . . . 8
2.1.4 Loi 09-08 (Maroc) . . . 9
2.2 Les cinq domaines retenus et leur justification . . . 9
2.2.1 Correspondance avec les référentiels internationaux . . . 9
2.2.2 Justification académique du choix de 5 domaines et 25 questions . . . 10

3 Conception et réalisation . . . 12
3.1 Méthodologie et démarche . . . 12
3.2 Architecture du système . . . 12
3.2.1 Vue d'ensemble . . . 12
3.2.2 Stack technique retenue . . . 13
3.2.3 Justification des choix technologiques . . . 13
3.2.4 Structure des fichiers . . . 14
3.3 Modélisation . . . 14
3.3.1 Schéma de données . . . 14
3.3.2 Questionnaire . . . 15
3.3.3 Méthodologie de scoring . . . 15
3.3.4 Diagrammes UML . . . 17
3.4 Réalisation . . . 18
3.4.1 Interface applicative . . . 18
3.4.2 Comprendre son score . . . 19
3.4.3 Des priorités pilotées par les réponses . . . 19
3.4.4 Export PDF . . . 19
3.4.5 Badge, compte et historique . . . 20
3.4.6 Sécurité de l'application . . . 20
3.4.7 Profils fictifs de test intégrés . . . 21
3.5 Référence des modules . . . 21
3.5.1 `scoring.py` – moteur de calcul du score . . . 21
3.5.2 `database.py` – accès aux données . . . 22
3.5.3 Autres modules . . . 22
3.6 Tests et validation . . . 23
3.7 Fonctionnalités au-delà du périmètre strict . . . 24
3.8 Résultats obtenus . . . 24
3.9 Limites observées . . . 24
3.10 Perspectives d'amélioration . . . 25

Conclusion générale et perspectives . . . 26

Bibliographie . . . 28

Annexes **30**

Table des figures

1.1 Organigramme simplifié du CMRPI 5
1.2 Diagramme de Gantt du stage 7

3.1 Architecture de l'application finale Pentascore 12
3.2 Diagramme entité-association simplifié du schéma de données 15
3.3 Diagramme de cas d'utilisation (version simplifiée) 17
3.4 Parcours utilisateur de l'application finale 18
3.5 Rendre le score explicable 19
3.6 Rapport PDF de trois pages 20
3.7 Partager sa démarche et suivre ses progrès 20

Liste des tableaux

1.1 Évolution des signalements EMC-Helpline (2021–2024) 4
1.2 Cahier des charges du projet 6
1.3 Planning du projet en quatre jalons 7

2.1 Les 5 domaines du questionnaire et leur correspondance normative 9

3.1 Technologies et outils de développement 13
3.2 Exemple d'échelle de Likert contextualisée (domaine Gouvernance) 15
3.3 Seuils de maturité cybersécurité 16
3.4 Profils de test et scores obtenus 17
3.5 Fonctions publiques de `scoring.py` (dépôt public) 21
3.6 Fonctions principales de `database.py` 22
3.7 Répartition des tests côté serveur 23
B.1 Colonnes de la table `pme` 31
B.2 Colonnes de la table `audit` 31
D.1 Foire aux questions – incidents rencontrés et solutions 32

Liste des Algorithmes

1 Sélection des recommandations priorisées 16

Liste des abréviations

API Application Programming Interface. 6, 12–14, 22, 24, 25

AUSIM Association des Utilisateurs des Systèmes d'Information au Maroc. 1, 5, 8, 10, 25, 26

CMMI Capability Maturity Model Integration. 16

CMRPI Centre Marocain de Recherches Polytechniques et d'Innovation. vi, x, 1–5, 7, 8, 10, 25–27

CNLCC Campagne Nationale de Lutte Contre la Cybercriminalité. 3

CNMC Campagne Nationale Maroc Cyberconfiance. 3

EMC Espace Maroc Cyberconfiance. 3

IA Intelligence Artificielle. 3

IoT Internet of Things. 3

ISO 27001 Norme internationale de gestion de la sécurité de l'information. 1, 8–10, 26

NIST CSF National Institute of Standards and Technology Cybersecurity Framework. 1, 8–10, 26

OCPI Observatoire Cybersécurité et Protection sur Internet. 3

PDF Portable Document Format. 5–7, 13, 19, 22–24, 26

PME Petite et Moyenne Entreprise. 1, 4–6, 9, 10, 13–17, 21–27, 31

Introduction générale

Dans un contexte de digitalisation croissante, les Petite et Moyenne Entreprise (PME) marocaines restent particulièrement exposées aux risques cybersécurité, sans toujours disposer des moyens de les évaluer ni de les prioriser. Le CMRPI, à travers son expertise en formation et sensibilisation à la cybersécurité, dispose d'un référentiel de bonnes pratiques élaboré avec l'Association des Utilisateurs des Systèmes d'Information au Maroc (AUSIM), mais celui-ci reste aujourd'hui un document statique, non opérationnalisé sous forme d'outil d'auto-diagnostic.

Le présent travail s'inscrit dans le cadre d'un stage de Projet de Fin d'Année (PFA) réalisé au sein du CMRPI – Espace Maroc Cyberconfiance, pour la formation d'Ingénieur d'État en **Intelligence Artificielle et Cybersécurité (IACS)** à l'École Nationale des Sciences Appliquées de Béni Mellal.

La problématique abordée concerne la conception d'une plateforme simple et accessible permettant à une PME marocaine d'auto-évaluer sa maturité cybersécurité à partir du guide CMRPI/AUSIM, et d'obtenir des recommandations priorisées et actionnables. Pour y répondre, je propose une plateforme combinant un questionnaire structuré, un moteur de scoring automatisé fondé sur des référentiels normatifs reconnus, et la génération de rapports personnalisés.

Ce rapport est organisé en trois chapitres principaux :

- **Chapitre I – Contexte général et problématique :** présentation du CMRPI, de la problématique et du cahier des charges du stage.
- **Chapitre II – État de l'art :** analyse des référentiels normatifs mobilisés (guide CMRPI/AUSIM, Norme internationale de gestion de la sécurité de l'information (ISO 27001), National Institute of Standards and Technology Cybersecurity Framework (NIST CSF), loi 09-08) et justification académique de la méthodologie retenue.
- **Chapitre III – Conception et réalisation :** description de l'architecture proposée, des choix technologiques, de la méthodologie de scoring, de l'implémentation et des résultats obtenus.

Contexte général et problématique

Introduction

Ce chapitre présente le contexte général du stage, l'organisme d'accueil, la problématique identifiée ainsi que le cahier des charges établi. Il constitue le socle sur lequel repose l'ensemble du travail réalisé dans le cadre de ce stage de Projet de Fin d'Année (PFA).

1.1 Présentation de l'organisme d'accueil

1.1.1 Historique et création du CMRPI

Le CMRPI est une association savante marocaine à but non lucratif, fondée en **juin 2012** [1]. Il a été créé à l'initiative du Pr. Youssef Bentaleb, enseignant-chercheur en analyse et modélisation mathématiques et informatique à l'Université Ibn Tofail de Kénitra, et ancien cadre supérieur d'un département ministériel. Parmi les membres fondateurs figurent notamment le Pr. Moulay Taib Belghiti et le Pr. Khalid Chougdali, tous deux rattachés à l'Université Ibn Tofail de Kénitra.

Le CMRPI poursuit plusieurs missions statutaires [1] :

- Rassembler les personnes physiques et morales concernées par les sciences et techniques ;
- Faciliter l'implication des chercheurs marocains, au pays et à l'étranger, dans le développement du Maroc ;
- Contribuer au transfert du savoir vers le milieu socio-économique national et international ;
- Distinguer les meilleurs spécialistes et favoriser les contacts entre chercheurs ;
- Développer une source d'informations spécialisées et d'expertise de haut niveau ;
- Représenter ses membres auprès d'autres sociétés scientifiques marocaines ou étrangères.

Le CMRPI se positionne ainsi comme un carrefour entre recherche, développement et innovation, constituant une « voie distincte de l'industrie et des instances gouvernementales pour la genèse et la diffusion des idées » [1].

1.1.2 Formations cybersécurité du CMRPI

Depuis 2014, le CMRPI a mené la première campagne de sensibilisation et de formation à la lutte contre la cybercriminalité au Maroc, sous l'égide du Ministère de l'Industrie, de l'Investissement, du Commerce et de l'Économie Numérique, à travers l'Observatoire Cybersécurité et Protection sur Internet (OCPI) [2]. Deux campagnes nationales ont été dirigées par le Pr. Youssef Bentaleb, Président du CMRPI :

- la Campagne Nationale de Lutte Contre la Cybercriminalité (CNLCC), entre 2014 et 2017 ;
- la Campagne Nationale Maroc Cyberconfiance (CNMC), entre 2018 et 2022.

Les ateliers organisés entre 2014 et 2019 ont couvert des thématiques telles que la détection de cybermenaces, la gouvernance des systèmes d'information, les cyberattaques avancées, la gestion d'incidents et de crise, la blockchain et l'Intelligence Artificielle (IA) appliquées à la cybersécurité, ainsi que la sécurité du Cloud [2]. Ces thématiques sont directement en lien avec les cinq domaines retenus pour le questionnaire d'auto-évaluation développé dans le cadre de ce stage (Gouvernance, Accès, Infrastructure, Incidents, Sensibilisation), ce qui illustre la continuité entre l'expertise historique du CMRPI et le projet réalisé.

1.1.3 Espace Maroc Cyberconfiance (EMC)

L'Espace Maroc Cyberconfiance (EMC) est une initiative du CMRPI lancée en septembre 2020, avec l'appui du Conseil de l'Europe [5]. Il s'agit d'une plateforme nationale de référence pour la prévention et la protection numérique des enfants, des jeunes et des femmes au Maroc, à travers des actions de sensibilisation et de traitement des signalements de cyberviolence et de cyberharcèlement.

L'équipe CMRPI-EMC en 2021 était composée de Youssef Bentaleb (Président), El Mehdi Erroussafi (cybersécurité), Ahmed Laftimi (projets digitaux), Houda Adli (protection des données), Hind El Makhtoum (sécurité Internet of Things (IoT)), Raouya Aknin (sécurité et blockchain), Sara Jeddin (statistiques), Yasmina Al Marouni (analyse des données), Chaimaa Mouad (sécurité biométrique), Safae El Makhtoum et Lamiaa Moujane (développement web), Safaouane Lammari (cybersécurité) et Lucie Allingri Chevallet (protection de l'enfance), avec l'appui de l'experte internationale Janice Richardson (Luxembourg) [5].

L'EMC s'appuie sur le portail trilingue (arabe, français, anglais) `www.cyberconfiance.ma`, ainsi que sur deux dispositifs opérationnels : EMC-Helpline et EMC-Stopline. Le lancement officiel d'EMC-Helpline a eu lieu le 7 février 2023, sous l'égide du Ministère de la Transition Numérique et de la Réforme de l'Administration, avec des conventions signées avec le Ministère de la Jeunesse, de la Culture et de la Communication et le Ministère de l'Éducation Nationale, ainsi que des partenariats associatifs avec l'Association ATEC et l'Association Ibny pour l'accompagnement juridique et psychologique [6]. Le dispositif a été étendu en 2024 avec le service « EMC Helpline for Women », à l'occasion de sa quatrième édition, avec pour partenaires institutionnels le Conseil de l'Europe, le Ministère de la Transition Numérique, le

Ministère de l'Éducation Nationale, le Ministère de la Justice, le Ministère de la Jeunesse, de la Culture et de la Communication, la Présidence du Ministère Public, la Direction Générale de la Sûreté Nationale (DGSN) et la Gendarmerie Royale, ainsi que les partenaires technologiques Meta, TikTok et Kaspersky [7].

Le tableau 1.1 présente l'évolution des signalements traités par EMC-Helpline entre 2021 et 2024 [8].

TABLE 1.1 – Évolution des signalements EMC-Helpline (2021–2024)

Année	Signalements	Évolution
2021	64 (05/07 – 31/12/2021)	—
2022	548 (04/01 – 25/12/2022)	×8,5
2023	1 227 (pic — séisme d'Al Haouz)	×2,2
2024	574	repli post-pic

Le détail par plateforme illustre l'évolution des usages numériques concernés : en 2021, les contenus signalés provenaient majoritairement d'Instagram (84,1 %), devant Facebook (14,3 %) et WhatsApp (1,6 %), la cyberviolence représentant 74,6 % des signalements et le discours de haine 9,5 %, avec une nette prédominance de la langue française (96,83 %) sur l'arabe (3,17 %) ; en 2022, Facebook est devenu la première plateforme concernée (70,52 %), devant Instagram (20,52 %), avec une majorité de signaleurs de sexe masculin (64,68 % contre 35,32 % de femmes) [8].

Note

Ces statistiques d'EMC-Helpline concernent la cyberviolence envers les particuliers (enfants et femmes), un périmètre différent de celui de ce stage, centré sur la maturité cybersécurité des PME. Elles sont présentées ici uniquement comme contexte général illustrant l'engagement et la légitimité du CMRPI en matière de cybersécurité, et ne constituent pas des données directement liées au projet réalisé.

1.1.4 Structure organisationnelle

La figure 1.1 présente l'organigramme simplifié du CMRPI, structuré autour de la présidence et de trois pôles d'activité.

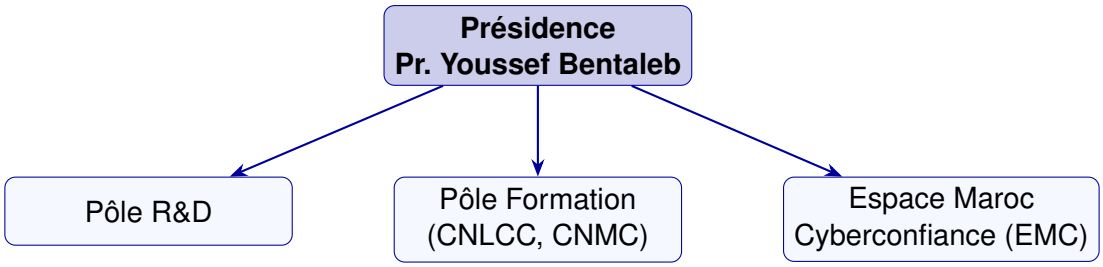


FIGURE 1.1 – Organigramme simplifié du CMRPI

1.2 Problématique et objectifs

1.2.1 Problématique

Les PME marocaines ne disposent pas, à ce jour, d'un outil simple et accessible leur permettant d'évaluer leur propre niveau de maturité en matière de cybersécurité. Le CMRPI dispose pourtant d'un référentiel de bonnes pratiques élaboré en partenariat avec l'AUSIM (guide CMRPI/AUSIM), mais celui-ci reste un document statique d'une quarantaine de pages, non opérationnalisé sous forme d'outil d'auto-diagnostic. Ce constat a motivé la définition de la problématique suivante :

Problématique

Comment concevoir une plateforme simple et accessible permettant à une PME marocaine d'auto-évaluer sa maturité cybersécurité à partir du guide CMRPI/AUSIM, et d'obtenir des recommandations priorisées et actionnables ?

Note

Les principaux enjeux identifiés sont l'accessibilité de l'outil pour un public non technique (dirigeants de PME), la fiabilité de la méthodologie de scoring, la pertinence des recommandations générées et la simplicité de déploiement de la solution.

1.2.2 Objectifs du projet

L'objectif principal de ce stage est de développer une plateforme d'auto-évaluation de la maturité cybersécurité pour les PME marocaines, basée sur le guide CMRPI/AUSIM, intégrant un scoring automatisé et des recommandations personnalisées.

Les objectifs secondaires associés sont :

- Proposer une auto-évaluation accessible sans compétence technique préalable ;
- Garantir un scoring automatisé et reproductible, exprimé sur une échelle de 0 à 100 ;
- Générer des rapports Portable Document Format (PDF) personnalisés pour chaque PME évaluée ;

- Assurer la conformité à la loi 09-08 relative à la protection des données à caractère personnel ;
- Sensibiliser les PME aux enjeux de la cybersécurité.

1.2.3 Périmètre du projet

Le périmètre retenu pour le stage inclut un questionnaire de 25 questions, un moteur de scoring, l'export des résultats au format PDF et une interface web. Un prototype Streamlit a d'abord servi à valider le moteur ; l'application finale repose sur React et FastAPI (voir chapitre 3). Sont en revanche exclus du périmètre du stage, et identifiés comme perspectives futures : l'authentification multi-tenant en production, le benchmarking inter-PME, la certification « PME Cyber-Sûre » et l'exposition d'une Application Programming Interface (API) publique.

1.2.4 Cahier des charges

Le tableau 1.2 résume les spécifications fonctionnelles et non fonctionnelles retenues pour le projet.

TABLE 1.2 – Cahier des charges du projet

Critère	Description
Fonctionnalité 1	Questionnaire d'auto-évaluation de 25 questions réparties sur 5 domaines de cybersécurité
Fonctionnalité 2	Moteur de scoring automatisé produisant un score par domaine et un score global (0–100)
Fonctionnalité 3	Génération de recommandations personnalisées et priorisées selon les réponses faibles
Fonctionnalité 4	Export du rapport de résultats au format PDF
Conformité	Recueil du consentement explicite de l'utilisateur (loi 09-08)
Accessibilité	Interface utilisable sans compétence technique par un dirigeant de PME
Déploiement	Application mono-bloc déployable simplement, sans infrastructure serveur dédiée

1.3 Planification du projet

Le stage s'est déroulé du **15 juillet** au **31 août 2026**, soit une durée de sept semaines, organisée en trois jalons validés successivement par l'encadrant professionnel. Un quatrième jalon, mené dans le prolongement du stage, a transformé le prototype en application finale. Le tableau 1.3 détaille ce découpage et son statut de réalisation.

TABLE 1.3 – Planning du projet en quatre jalons

Jalon	Période	Objectif	Statut
1	15–31 juil. 2026	Analyse et conception (questionnaire, méthodologie de scoring)	Validé
2	1–15 août 2026	Interface Streamlit fonctionnelle et tests	Complété
3	16–31 août 2026	Export PDF, tests de bout en bout, documentation	Complété
4	Prolongement	Application finale React + FastAPI, cohérence, badge, historique, hors ligne	Complété

La figure 1.2 illustre ce planning sous forme de diagramme de Gantt.

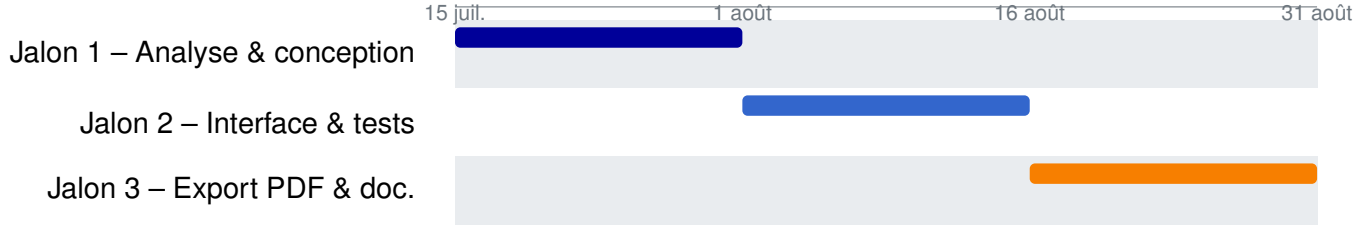


FIGURE 1.2 – Diagramme de Gantt du stage

Conclusion

Ce chapitre a permis de situer le cadre général du stage, de présenter le CMRPI et son initiative EMC, puis de définir la problématique et le cahier des charges du projet. Le chapitre suivant est consacré à l'analyse des référentiels normatifs mobilisés pour construire la méthodologie d'auto-évaluation.

État de l'art

Introduction

Ce chapitre présente l'analyse des référentiels normatifs mobilisés pour concevoir la méthodologie d'auto-évaluation de la plateforme. Contrairement à une étude comparative d'outils concurrents existants, ce chapitre est centré sur l'analyse du guide CMRPI/AUSIM et sa mise en correspondance avec les référentiels internationaux ISO 27001 et NIST CSF, ainsi que sur la justification académique des choix méthodologiques retenus pour le questionnaire.

2.1 Référentiels normatifs analysés

2.1.1 Guide CMRPI/AUSIM

Le guide des bonnes pratiques CMRPI/AUSIM [3] est un document de référence d'une quarantaine de pages, élaboré conjointement par le CMRPI et l'AUSIM. Il couvre cinq domaines de bonnes pratiques en cybersécurité, alignés avec les standards internationaux présentés ci-après. C'est ce guide qui constitue la base de contenu du questionnaire d'auto-évaluation développé dans le cadre de ce stage.

2.1.2 ISO/IEC 27001 :2022

L'ISO 27001 [10] est le référentiel international de gestion de la sécurité de l'information le plus largement reconnu. Il définit les exigences relatives à la mise en place, à la mise en œuvre, à la maintenance et à l'amélioration continue d'un système de management de la sécurité de l'information. Dans le cadre de ce projet, les 93 contrôles de l'Annexe A de la norme, organisés en quatre thèmes (A.5 Organisationnel, A.6 Personnes, A.7 Physique, A.8 Technologique), ont été regroupés conceptuellement en cinq domaines afin de les rendre exploitables par un questionnaire court et compréhensible par un public non technique — ce regroupement est détaillé en section 2.2.

2.1.3 NIST Cybersecurity Framework 2.0

Le NIST CSF [11] structure la gestion des risques cybersécurité autour de six fonctions : *Govern* (gouverner), *Identify* (identifier), *Protect* (protéger), *Detect* (détecter), *Respond* (répondre) et *Recover* (récupérer) – la fonction *Govern* ayant été ajoutée aux cinq fonctions d'origine (*Identify*, *Protect*, *Detect*, *Respond*, *Recover*) lors de la publication de la version 2.0 du ré-

férentiel en février 2024. Une correspondance conceptuelle a été établie entre ces six fonctions et les cinq domaines du questionnaire, ce qui a permis de vérifier la cohérence et l'exhaustivité relative de la couverture retenue.

2.1.4 Loi 09-08 (Maroc)

La loi 09-08 [13] relative à la protection des personnes physiques à l'égard du traitement des données à caractère personnel encadre, au Maroc, la collecte et le traitement des données personnelles. Dans la plateforme développée, cette exigence réglementaire est intégrée sous la forme d'un consentement explicite recueilli via une case à cocher obligatoire lors de l'inscription de l'utilisateur, préalablement à toute collecte de données relatives à la PME évaluée.

Maturité cybersécurité

La maturité cybersécurité désigne le degré auquel les pratiques, processus et contrôles de sécurité d'une organisation sont formalisés, appliqués de manière cohérente et intégrés à sa gouvernance. Elle se mesure généralement par paliers croissants, du niveau le plus faible (pratiques absentes ou ad hoc) au niveau le plus avancé (pratiques formalisées, mesurées et communiquées).

2.2 Les cinq domaines retenus et leur justification

2.2.1 Correspondance avec les référentiels internationaux

Le tableau 2.1 présente les cinq domaines retenus pour structurer le questionnaire d'auto-évaluation, ainsi que leur correspondance avec les sections de l'ISO 27001 et les fonctions du NIST CSF.

TABLE 2.1 – Les 5 domaines du questionnaire et leur correspondance normative

#	Domaine	Réf. ISO 27001	Réf. NIST CSF
1	Gouvernance	A.5.1–A.5.2 (Politiques, rôles)	Govern
2	Accès & Identités	A.5.16–A.5.18, A.8.2, A.8.5 (Gestion des identités et des accès)	Protect
3	Infrastructure & Réseau	A.8.20–A.8.23 (Sécurité réseau)	Identify / Protect
4	Incidents & Continuité	A.5.24–A.5.28, A.8.14 (Gestion des incidents, continuité)	Detect / Respond / Recover
5	Sensibilisation & Formation	A.6.3 (Sensibilisation et formation)	Protect

2.2.2 Justification académique du choix de 5 domaines et 25 questions

Le choix d'un questionnaire structuré en cinq domaines de cinq questions chacun, soit 25 questions au total, repose sur deux fondements académiques et une décision de conception assumée.

Fondements issus du CMM/CMMI. Le modèle de maturité par paliers proposé par Humphrey [9] dans *Managing the Software Process* définit cinq niveaux de maturité croissants. Cette structuration en paliers a inspiré les niveaux de maturité du moteur de scoring : quatre niveaux (Critique, Faible, Moyen, Avancé), séparés par trois seuils réguliers (25, 50 et 75), ont été retenus pour rester lisibles par un dirigeant (voir chapitre 3, section 3.3.3).

Échelle de Likert à cinq niveaux. Les travaux de Dawes [4] sur la comparaison des échelles de Likert à 5, 7 et 10 points montrent que les échelles à 5 et à 7 points donnent des résultats comparables une fois ramenés à la même échelle. L'échelle à cinq niveaux offre donc un bon compromis entre simplicité de réponse et granularité, en particulier pour un public non spécialiste. Ce résultat a motivé le choix d'une échelle de Likert à cinq niveaux pour chaque question du questionnaire, avec des libellés contextualisés propres à chaque question plutôt qu'une simple graduation numérique de 1 à 5.

Décision de conception sur le nombre de questions. Le choix de cinq questions par domaine, plutôt qu'un nombre plus élevé, résulte d'un arbitrage assumé entre la couverture de chaque domaine et la longueur totale du parcours pour un public non spécialiste (dirigeants de PME) : au-delà du minimum généralement recommandé de trois items pour caractériser une dimension de manière stable, cinq questions par domaine permettent de couvrir les principales pratiques du guide CMRPI/AUSIM sans dépasser un total de 25 questions, jugé raisonnable pour un outil d'auto-évaluation complété en une seule session.

Note

Ces deux fondements académiques, complétés par la décision de conception exposée ci-dessus, justifient conjointement la structure retenue pour le questionnaire : 5 domaines $\times$ 5 questions, avec une échelle de réponse de Likert à 5 niveaux à libellés contextualisés. Cette structure conditionne directement la méthodologie de scoring présentée au chapitre 3.

Conclusion

Ce chapitre a permis d'analyser les référentiels normatifs mobilisés pour la conception du questionnaire d'auto-évaluation — le guide CMRPI/AUSIM, l'ISO 27001, le NIST CSF et la loi 09-08 — et de justifier académiquement la structure retenue en cinq domaines et 25 questions. Le chapitre suivant détaille la conception et la réalisation de la plateforme développée à partir

de cette analyse.

Conception et réalisation

Introduction

Ce chapitre détaille la démarche de conception de la plateforme, l'architecture retenue et les choix technologiques associés, la modélisation des données et de la méthodologie de scoring, ainsi que les principales étapes de réalisation, de test et de validation. Il présente également les résultats obtenus, les limites observées et les perspectives d'amélioration identifiées à l'issue du stage.

3.1 Méthodologie et démarche

Le projet a été mené selon une démarche itérative en trois jalons, conforme au planning présenté au chapitre 1 (section 1.3). Chaque jalon a fait l'objet de points de contrôle hebdomadaires avec l'encadrant professionnel, le Dr. Rachid Abouettahir, ainsi que d'un rapport de progression écrit en fin de jalon. Les trois rapports de progression produits (Jalon 1, Jalon 2, Jalon 3) documentent l'avancement jour par jour et ont été intégralement transmis et validés par l'encadrant. Le prototype ainsi validé, développé avec Streamlit, a ensuite été reconstruit dans un quatrième jalon en application finale, **Pentascore**, décrite dans la suite de ce chapitre.

3.2 Architecture du système

3.2.1 Vue d'ensemble

L'architecture a évolué en deux temps. Le prototype reposait sur un seul processus Streamlit, qui servait l'interface et exécutait la logique métier. L'application finale sépare l'interface, l'API et le moteur métier (figure 3.1), tout en restant servie par un seul processus.

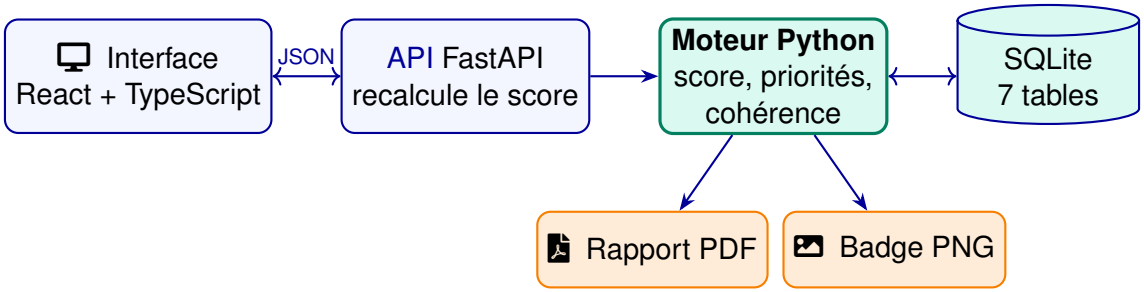


FIGURE 3.1 – Architecture de l'application finale Pentascore

Le calcul du score n'existe qu'à un seul endroit, le module `src/scoring.py`. L'interface envoie les réponses brutes ; le serveur recalcule toujours le score, les priorités, le rapport PDF et l'historique. Un score modifié dans le navigateur n'a donc aucun effet.

3.2.2 Stack technique retenue

Le tableau 3.1 résume les technologies de l'application finale.

TABLE 3.1 – Technologies et outils de développement

Catégorie	Outil	Rôle
Interface	React, TypeScript, Vite	Parcours, questionnaire, résultats animés, historique
API	FastAPI (Python)	Routes JSON, sessions, limitation de débit, service de l'interface compilée
Moteur métier	Python (`src/`)	Score, recommandations, cohérence, rapport PDF, badge
Base de données	SQLite	Questions, 47 recommandations, comptes et évaluations
Génération	ReportLab [12], Pillow	Rapport PDF de 3 pages avec QR code ; badge PNG
Sécurité	bcrypt, cookie HttpOnly	Mots de passe hachés, session `SameSite=Strict`
Tests	pytest, Vitest, Playwright	Tests serveur, tests d'interface, parcours de bout en bout

3.2.3 Justification des choix technologiques

Streamlit d'abord, pour valider vite. Streamlit [14] a permis de construire en quelques jours un prototype complet, sans séparer interface et serveur. C'était le bon outil pour valider le questionnaire, la formule et les priorités avec l'encadrant.

React et FastAPI ensuite, pour l'application finale. Une fois la méthode validée, Streamlit montrait ses limites : peu de contrôle sur l'interface, rechargement complet à chaque clic, et une logique métier mêlée à l'affichage. La séparation React / FastAPI apporte une interface plus claire pour un dirigeant non technique, une API qui reste la seule source de vérité pour le score, et un moteur métier testable seul.

SQLite plutôt que PostgreSQL. SQLite tient dans un seul fichier, sans serveur à installer, et suffit pour une instance unique. Le passage à PostgreSQL pour un déploiement en ligne ne change pas le moteur (voir section 3.10).

Tout en local, hors ligne. Les réponses d'une PME décrivent ses failles : elles ne doivent partir vers aucun service tiers. Les polices sont embarquées, la politique de sécurité du contenu

(CSP) est limitée à l'origine de l'application, et un test de bout en bout vérifie qu'aucune requête ne sort vers un domaine extérieur.

3.2.4 Structure des fichiers

Le moteur métier (`src/`) ne dépend ni de l'interface ni de l'API : il est réutilisé tel quel par FastAPI et testé en isolation. L'arborescence du dépôt est la suivante :

```
cmrpi-platform/
|-- api/                        # API FastAPI (routes, securite)
|-- frontend/                   # React + Vite + TypeScript
|   |-- src/components/         # ecrans du parcours
|   |-- src/state/              # logique du parcours (pure, testee)
|   `-- e2e/                    # parcours de bout en bout (Playwright)
|-- src/
|   |-- scoring.py              # Score, priorites, points perdus
|   |-- consistency_checker.py# 30 regles de coherence
|   |-- pdf_generator.py        # Rapport PDF (page 1, QR code)
|   |-- pdf_annex.py            # Pages 2 et 3 du rapport
|   |-- badge_generator.py      # Badge PNG partageable
|   |-- templates.py            # Fiche de poste RSSI junior
|   |-- auth.py, database.py    # Comptes (bcrypt), acces SQLite
|   `-- questionnaire.py, test_profiles.py
|-- data/                       # questions, regles, schema SQL
|-- tests/                      # 285 tests (pytest)
|-- docs/                       # Scoring_Rules_V1.md, presentation
`-- .github/workflows/ci.yml    # Integration continue
```

Listing 3.1 – Structure des fichiers du dépôt

3.3 Modélisation

3.3.1 Schéma de données

Le modèle de données repose sur sept tables : `pme`, `domain`, `question`, `audit`, `audit_response`, `recommendation` et `audit_log`. Les relations principales sont les suivantes : une PME peut réaliser plusieurs audits ; chaque audit comporte 25 réponses ; les 25 questions sont réparties en 5 domaines de 5 questions chacun ; chaque recommandation est rattachée à un domaine et caractérisée par une sévérité (*Critical*, *High*, *Medium*, *Low*). La figure 3.2 présente le diagramme entité-association simplifié.

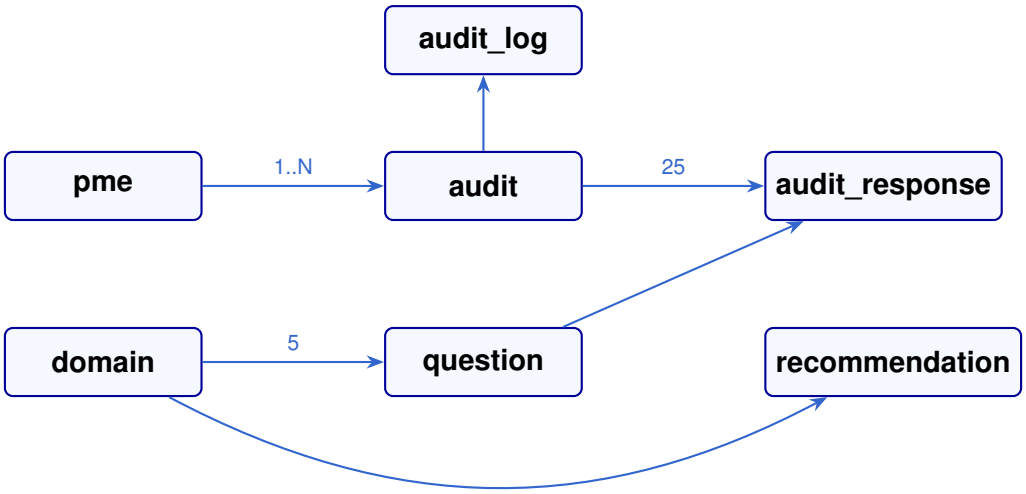


FIGURE 3.2 – Diagramme entité-association simplifié du schéma de données

3.3.2 Questionnaire

Le questionnaire comprend 25 questions réparties sur les 5 domaines présentés au chapitre 2, disponibles en français et en anglais avec un texte de guidance associé à chaque question. Le format retenu est une échelle de Likert à cinq niveaux, dont les libellés sont contextualisés à chaque question plutôt que numériques génériques. Le tableau 3.2 illustre ce principe pour une question relative à la politique de gouvernance.

TABLE 3.2 – Exemple d'échelle de Likert contextualisée (domaine Gouvernance)

Niveau	Libellé
1	Non
2	Partiellement
3	Approuvée (1–2 ans)
4	Approuvée + revue annuelle
5	Approuvée + revue + communiquée

3.3.3 Méthodologie de scoring

La méthodologie de scoring constitue le cœur méthodologique du projet. Le score d'un domaine est calculé à partir de la moyenne des réponses de Likert (1 à 5) obtenues pour les cinq questions de ce domaine, ramenée à une échelle de 0 à 100 selon l'équation (3.1) :

$$\text{Score}_{\text{domaine}} = \frac{\overline{\text{Likert}} - 1}{4} \times 100 \tag{3.1}$$

où $\overline{\text{Likert}}$ désigne la moyenne des réponses du domaine sur l'échelle de 1 à 5. Le score global de la PME est ensuite obtenu par la moyenne arithmétique des cinq scores de domaine, selon l'équation (3.2) :

$$\text{Score}_{\text{global}} = \frac{1}{5} \sum_{i=1}^{5} \text{Score}_{\text{domaine}_i} \tag{3.2}$$

Le score global obtenu est ensuite interprété selon quatre niveaux de maturité. Les seuils retenus, présentés au tableau 3.3 sous forme d'intervalles semi-ouverts sans chevauchement de bornes, sont inspirés de la structuration en paliers du modèle Capability Maturity Model Integration (CMMI) [9] et correspondent exactement à la logique de comparaison stricte (`score < threshold`) implémentée dans la fonction `get_maturity_level()` du module `src/scoring.py`.

TABLE 3.3 – Seuils de maturité cybersécurité

Plage de score	Niveau de maturité
$[0,25[$ %	Critique
$[25,50[$ %	Faible
$[50,75[$ %	Moyen
$[75,100]$ %	Avancé

Logique de sélection des recommandations

La sélection des recommandations a été affinée au cours du Jalon 3 afin de respecter précisément la consigne de l'encadrant : proposer deux à trois recommandations selon les réponses les plus faibles. L'algorithme 1 décrit cette logique, implémentée dans la fonction `generate_top_recommendations()` du module `src/scoring.py`.

Algorithme 1 : Sélection des recommandations priorisées

Entrée : Scores de domaine $\{S_1, \ldots, S_5\}$, catalogue de recommandations $\mathscr{R}$
Sortie : Liste priorisée de 2 à 3 recommandations
Trier les domaines par score croissant;
$\mathscr{L} \leftarrow \emptyset$;
pour *chaque domaine d, du plus faible au plus fort* **faire**
  si $S_d < 60\,\%$ **alors**
    Rechercher dans $\mathscr{R}$ les recommandations de sévérité {Critical, High} pour d;
  sinon
    Rechercher dans $\mathscr{R}$ les recommandations de sévérité {Medium, Low} pour d;
  Ajouter les recommandations trouvées à $\mathscr{L}$;
retourner *les 2 à 3 premières recommandations de* $\mathscr{L}$*, domaines faibles priorisés*

Validation par profils de test

La cohérence de la méthodologie de scoring a été vérifiée à l'aide de trois profils fictifs de PME, dont les résultats sont résumés au tableau 3.4.

TABLE 3.4 – Profils de test et scores obtenus

Profil	Secteur	Score global	Niveau
PME Finance	Finance	44,0 %	Faible
PME Commerce	Commerce	20,0 %	Critique
PME Technologie	Technologie	83,0 %	Avancé

Note

Les premiers calculs manuels réalisés au Jalon 1 comportaient une erreur d'addition, qui a été corrigée et revérifiée automatiquement lors du codage du moteur de scoring au Jalon 2. Cet épisode illustre l'intérêt d'une validation croisée entre un calcul manuel initial et son implémentation automatisée, et a été traité comme un point de rigueur méthodologique plutôt qu'un simple correctif.

3.3.4 Diagrammes UML

Huit diagrammes UML ont été produits au Jalon 1 (Mermaid.js) afin de formaliser la conception : diagramme de cas d'utilisation (3 acteurs, 9 cas d'utilisation), diagramme de séquence (audit PME, benchmark administrateur), diagramme de classes (7 classes), diagramme d'activité, diagramme d'état (5 états d'un audit), diagramme de composants (4 tiers) et diagramme de déploiement. Seul le diagramme de cas d'utilisation est reproduit dans ce rapport, sous une forme simplifiée redessinée en TikZ (figure 3.3) ; les sept autres diagrammes ne sont pas reproduits ici et restent disponibles dans leur intégralité dans le rapport de progression du Jalon 1, sur le dossier Drive du projet.

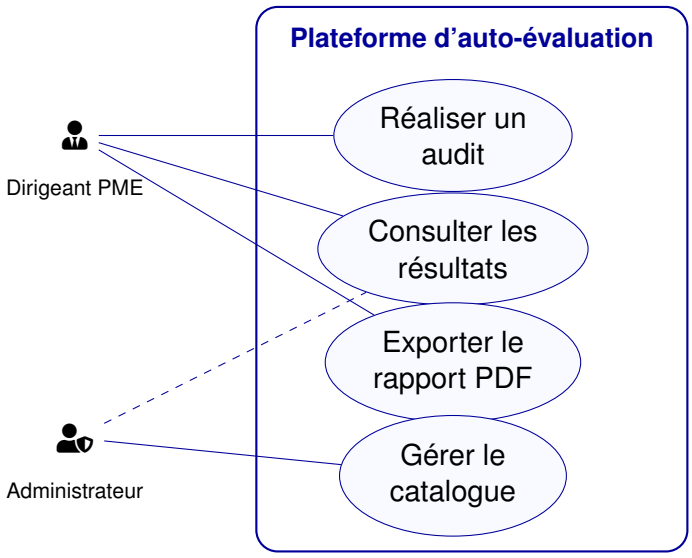


FIGURE 3.3 – Diagramme de cas d'utilisation (version simplifiée)

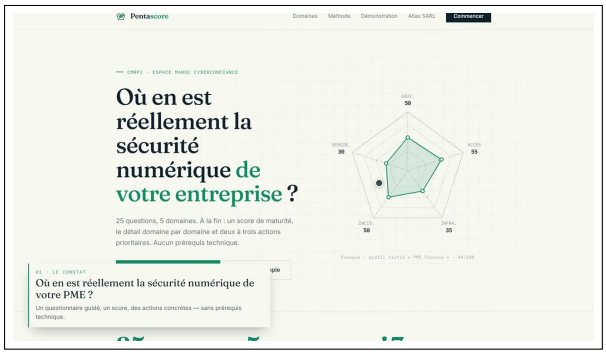
3.4 Réalisation

3.4.1 Interface applicative

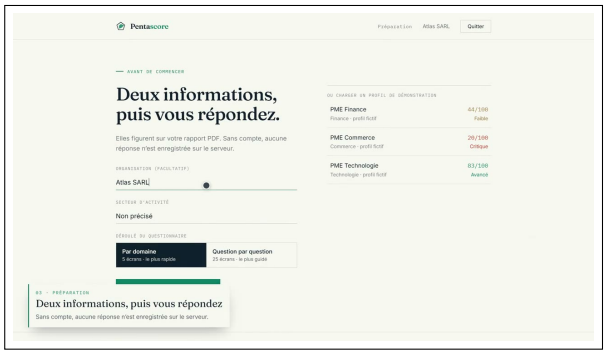
L'interface finale guide le dirigeant en quatre temps : l'accueil, une courte préparation, le questionnaire et le résultat (figure 3.4). Elle suit une direction graphique sobre, dite « relevé de précision », dont le pentagone des cinq domaines est la signature.

Note

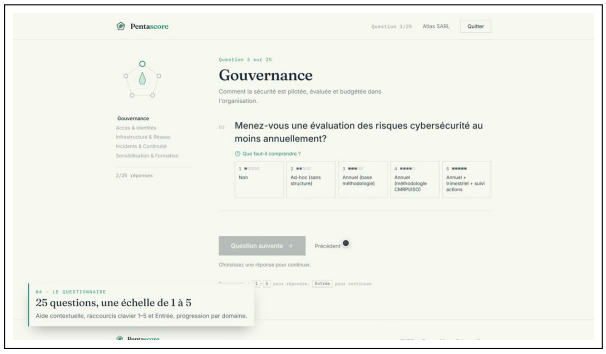
Le cahier des charges de l'encadrant spécifiait « une question par écran **ou** par section ». Les deux modes sont proposés au choix : cinq écrans de cinq questions, ou vingt-cinq écrans d'une question.



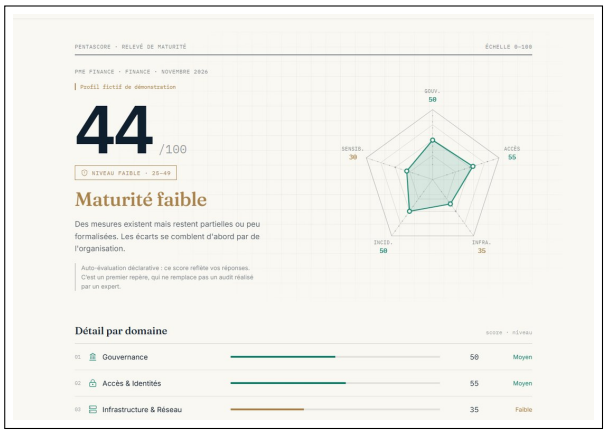
(a) Accueil



(b) Préparation et profils de démonstration



(c) Questionnaire



(d) Résultat : score, niveau, radar

FIGURE 3.4 – Parcours utilisateur de l'application finale

L'accueil (figure 3.4a) présente la démarche et ses limites. La préparation (figure 3.4b) demande deux informations facultatives, le nom et le secteur, et permet de charger un profil de démonstration. Le questionnaire (figure 3.4c) affiche pour chaque question une aide contextuelle et une échelle graduée de 1 à 5, utilisable au clavier. Le résultat (figure 3.4d) révèle le score, le sceau de niveau et le radar des cinq domaines, puis les priorités.

3.4.2 Comprendre son score

Deux fonctionnalités rendent le score explicable (figure 3.5) :

- **Rejouer le score.** Chaque question pèse $100/(5 \times 5) = 4$ points ; chaque cran perdu sur l'échelle coûte donc 1 point. Le panneau affiche les réponses qui ont coûté le plus de points. La somme des points perdus vaut exactement $100 -$ score, ce que vérifient les tests.
- **Points à revérifier.** Une auto-évaluation peut contenir des réponses contradictoires. Trente règles déterministes, de la forme « si la question A $\geq x$, la question B devrait être $\geq y$ », les signalent. Onze règles détectent deux réponses qui se contredisent, dix-neuf un prérequis manquant. Chaque règle cite une mesure de l'ISO/IEC 27001 :2022. Elles ne modifient jamais le score : elles invitent à vérifier.



(a) Rejouer le score



(b) Points à revérifier

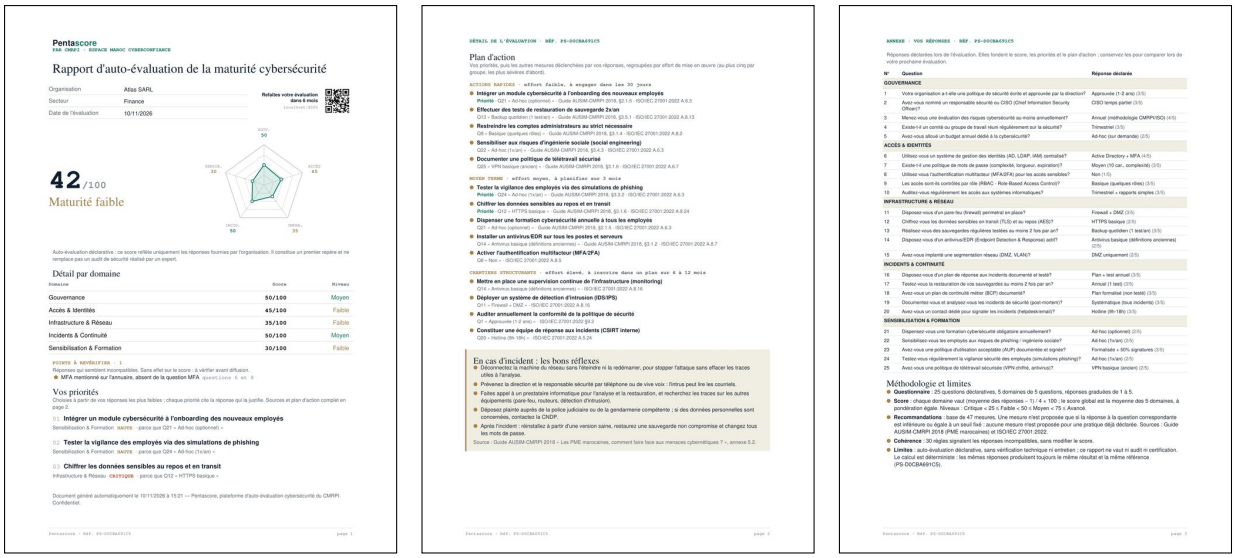
FIGURE 3.5 – Rendre le score explicable

3.4.3 Des priorités pilotées par les réponses

Chacune des 47 recommandations est liée à la question qu'elle corrige et à un seuil : elle n'apparaît que si la réponse est sous ce seuil. L'outil ne recommande donc jamais une pratique déjà déclarée. Chaque priorité affiche « parce que vous avez répondu… », avec au plus deux priorités par domaine. Chaque recommandation cite une double source : la section réelle du guide AUSIM-CMRPI (édition 2018) et la mesure de l'ISO/IEC 27001 :2022 ; un test bloque toute référence inexistante. Enfin, si le domaine Gouvernance est sous 50, un modèle de fiche de poste de RSSI junior est proposé.

3.4.4 Export PDF

Le rapport PDF compte trois pages (figure 3.6) : une synthèse avec le score, le radar et un QR code « Refaites votre évaluation dans 6 mois » ; un plan d'action classé par effort, avec les bons réflexes en cas d'incident ; puis les réponses déclarées, la méthodologie et les limites. Une référence calculée à partir des réponses figure en pied de page.

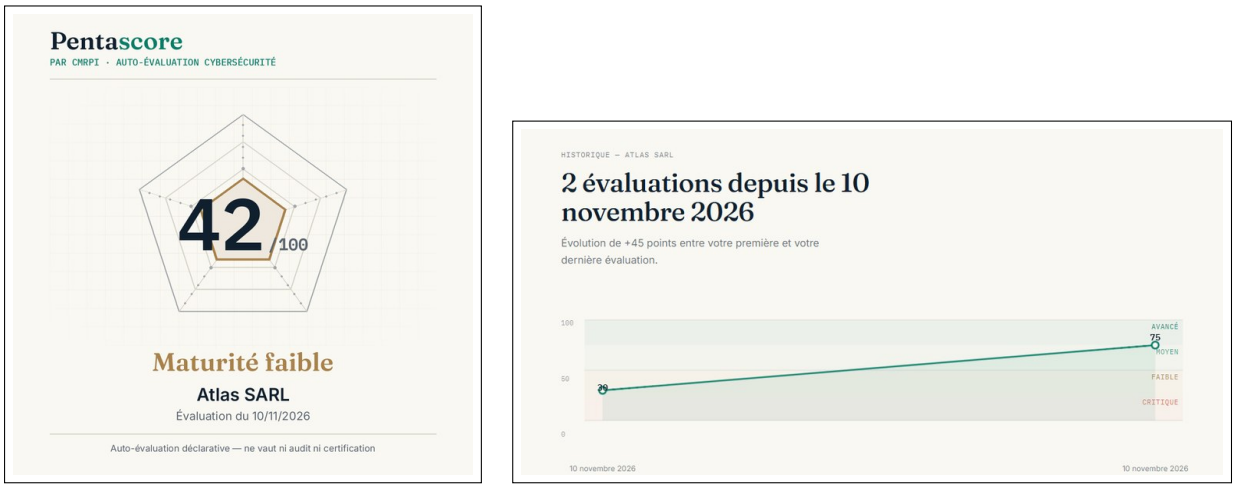


(a) Synthèse **(b)** Plan d'action **(c)** Réponses et méthode

FIGURE 3.6 – Rapport PDF de trois pages

3.4.5 Badge, compte et historique

Le **badge** est une image PNG générée localement : score, niveau, organisation, date et pentagone. Il porte la mention « auto-évaluation déclarative – ne vaut ni audit ni certification », pour ne jamais passer pour une certification. Le **compte** est facultatif : sans compte, aucune réponse n'est enregistrée côté serveur. Avec un compte, le consentement explicite est horodaté, conformément à la loi 09-08, et la suppression du compte efface toutes les données. L'**historique** montre l'évolution du score d'une évaluation à l'autre (figure 3.7).



(a) Badge partageable **(b)** Historique des évaluations

FIGURE 3.7 – Partager sa démarche et suivre ses progrès

3.4.6 Sécurité de l'application

Les mots de passe sont hachés avec bcrypt. La session repose sur un cookie `HttpOnly` et `SameSite=Strict`, signé par une clé secrète obligatoire en production. Les routes d'authen-

tification et de calcul sont protégées par une limitation de débit par adresse IP. Ces protections sont couvertes par une série de tests dédiés (`test_api_hardening.py`).

3.4.7 Profils fictifs de test intégrés

Conformément au brief du Jalon 2 (« tester avec 2–3 profils fictifs de PME »), les trois profils du tableau 3.4 se chargent en un clic depuis l'écran de préparation, via le module `src/test_profiles.py`.

3.5 Référence des modules

Cette section documente les fonctions publiques des principaux modules du dossier `src/`, à des fins de maintenabilité et de reprise du projet par un futur développeur.

3.5.1 `scoring.py` – moteur de calcul du score

Module Python pur, sans aucune dépendance externe (ni interface, ni base de données), ce qui permet de le tester et de le réutiliser indépendamment de l'interface. Le tableau 3.5 recense les principales fonctions publiques du module, telles qu'elles figurent dans le fichier `src/scoring.py` du dépôt public à la date de rédaction de ce rapport.

TABLE 3.5 – Fonctions publiques de `scoring.py` (dépôt public)

Fonction	Rôle
`calculate_domain_score(responses)`	Calcule le score (0–100) d'un domaine à partir de ses 5 réponses Likert
`calculate_domain_scores(responses_by_domain)`	Applique `calculate_domain_score` à chacun des domaines d'un dictionnaire {domaine : réponses}
`calculate_global_score(domain_scores)`	Moyenne des scores de domaine, arrondie à une décimale
`get_maturity_level(score)`	Retourne le niveau (Critique/Faible/Moyen/Avancé) selon le score
`get_severity_filter(domain_score)`	Retourne le couple (sévérités à interroger, nombre maximal de recommandations) selon le score du domaine (seuil à 60 %)
`generate_recommendations(domain_scores, get_recs_fn)`	Sélectionne, pour chaque domaine, les recommandations filtrées par sévérité et limitées par `get_severity_filter` – version initiale (Jalon 2), conservée dans le module

suite page suivante

Table 3.5 – suite de la page précédente

Fonction	Rôle
`generate_top_recommendations(domain_scores, get_recs_fn, limit)`	Sélectionne 2 à 3 recommandations globales priorisées, domaines les plus faibles en premier – correctif du Jalon 3 (voir section 3.3.3)
`score_full_audit(all_responses)`	Fonction principale : calcule scores de domaine, score global et niveau de maturité en un seul appel
`group_responses_by_domain(responses, question_domain_map)`	Regroupe les réponses brutes {question_id : valeur} par domaine à partir de la correspondance question → domaine

3.5.2 `database.py` – accès aux données

Toutes les fonctions de ce module utilisent un gestionnaire de contexte `get_connection()` qui active les clés étrangères SQLite et valide automatiquement (*commit*) les transactions. Le tableau 3.6 en présente les fonctions les plus significatives.

TABLE 3.6 – Fonctions principales de `database.py`

Fonction	Rôle
`init_database()`	Applique `data/schema.sql` (création des tables et amorçage des 5 domaines)
`seed_questions_and_domains(...)`	Charge les 25 questions depuis les fichiers JSON (idempotent)
`seed_recommendations_from_xlsx(xlsx_path)`	Charge les recommandations depuis le classeur Excel
`create_audit(pme_id)` / `complete_audit(...)`	Création d'un audit et clôture avec son score final
`save_response(...)`	Enregistre une réponse individuelle à une question
`get_audit_history(pme_id)`	Historique des audits réalisés par une PME
`log_action(pme_id, action, details)`	Journalisation d'une action dans `audit_log`

3.5.3 Autres modules

Le module `consistency_checker.py` charge et valide les 30 règles de cohérence, puis renvoie les points à revérifier. Les modules `pdf_generator.py` et `pdf_annex.py` construisent les trois pages du rapport PDF, QR code compris. `badge_generator.py` produit le badge PNG avec Pillow, `templates.py` la fiche de poste de RSSI junior. `auth.py` gère les comptes (bcrypt) et `database.py` l'accès à SQLite. Côté API, le dossier `api/` re-

groupe la configuration, la sécurité (sessions, limitation de débit) et les routes `assessment.py` et `accounts.py`. Enfin, `scoring.get_score_contributions()` calcule les points perdus question par question pour la fonction « rejouer le score ».

3.6 Tests et validation

Le score est un résultat auquel la PME va se fier : une erreur de calcul ferait perdre toute confiance. La qualité a donc été vérifiée à trois niveaux : 285 tests côté serveur (pytest), 71 tests côté interface (Vitest) et 13 parcours de bout en bout dans un vrai navigateur (Playwright), avec 98 % de couverture de code côté serveur comme côté interface. Le tableau 3.7 détaille les tests côté serveur.

TABLE 3.7 – Répartition des tests côté serveur

Fichier	Tests	Contenu
`test_consistency_checker.py`	111	Les 30 règles de cohérence, validation du fichier de règles
`test_api_assessment.py`	33	Routes de score, de rapport et d'historique
`test_scoring.py`	30	Formules, seuils, priorités, points perdus
`test_api_hardening.py`	22	Sessions, limitation de débit, entrées invalides
`test_database_pdf.py`	21	Base de données, rapport PDF, QR code décodé
`test_badge_generator.py`	17	Badge PNG
`test_api_accounts.py`	14	Inscription, consentement, suppression du compte
`test_auth.py`	13	Hachage et vérification des mots de passe
`test_questionnaire.py`	8	Chargement et validation du questionnaire
`test_templates.py`	7	Fiche de poste RSSI junior
`test_recommendations_data.py`	6	Références du guide et de l'ISO vérifiées
`test_profiles.py`	3	Les 3 profils de démonstration
Total	**285**	

Les 13 parcours de bout en bout démarrent leur propre serveur sur une base jetable. Ils couvrent les deux modes de questionnaire, le retour arrière, les trois profils, l'export PDF, l'inscription avec consentement, l'historique, la suppression du compte, les points à revérifier, le badge, le replay du score, la navigation au clavier, l'affichage mobile et l'absence de toute requête vers un domaine extérieur.

Un pipeline d'intégration continue (`.github/workflows/ci.yml`) s'exécute à chaque *push* : flake8 et pytest côté serveur, avec une couverture minimale de 90 % ; vérification des types, lint, tests et compilation côté interface ; puis les parcours de bout en bout.

⚠ Attention

Au Jalon 3, une installation sur environnement vierge du prototype Streamlit avait révélé trois régressions de dépendances (`pandas`, `streamlit`, `flake8`). Elles ont été corrigées et sont depuis prévenues par l'intégration continue.

3.7 Fonctionnalités au-delà du périmètre strict

Au-delà du cahier des charges initial (questionnaire, score, export PDF), l'application finale ajoute : le replay du score, les 30 règles de cohérence, des priorités pilotées par les réponses et doublement référencées, le rapport de trois pages avec QR code de réévaluation, le badge partageable, la fiche de poste de RSSI junior, le compte facultatif avec historique, et le fonctionnement entièrement hors ligne. Toutes ces fonctionnalités sont locales et déterministes : aucune ne dépend d'un service externe ni d'une clé d'API.

3.8 Résultats obtenus

La plateforme couvre le parcours complet questionnaire → score → priorités → rapport PDF → suivi. Le prototype a été validé par l'encadrant professionnel à chaque jalon (« bravo, un livrable de qualité » au Jalon 1, « merci pour les résultats » au Jalon 2). Le code source est disponible à l'adresse `https://github.com/YOUSSEFKARROUM/PFA_CRMPI`. Sur le plan de la qualité, le projet compte 285 tests côté serveur, 71 côté interface, 13 parcours de bout en bout, 98 % de couverture et une intégration continue complète.

3.9 Limites observées

Pentascore est un premier repère, pas encore une référence :

- **Une évaluation déclarative** : le score reflète les réponses, pas la réalité du terrain. Les règles de cohérence réduisent ce risque sans le supprimer.
- **Une validation sur trois PME fictives** : le moteur calcule juste, mais la justesse du diagnostic reste à prouver sur de vraies entreprises.
- **Des poids égaux et des seuils fixes** : chaque question vaut 4 points ; les seuils 25, 50 et 75 ne sont pas encore calibrés sur des données réelles.
- **Un référentiel figé, en français** : pas de comparaison entre PME d'un même secteur.
- **Une instance unique** : SQLite et la limitation de débit en mémoire ne conviennent pas à une montée en charge.

3.10 Perspectives d'amélioration

À chaque limite correspond une suite :

1. Demander des preuves (politique, capture) et proposer une évaluation accompagnée par le CMRPI.
2. Conduire un pilote avec de vraies PME, via le CMRPI et l'AUSIM, et comparer les résultats à l'avis d'un auditeur.
3. Pondérer selon la criticité et calibrer les seuils sur les données du pilote.
4. Proposer une version arabe, une comparaison par secteur, et mettre à jour le référentiel avec le guide, l'ISO et le NIST.
5. Déployer la plateforme en ligne avec une base PostgreSQL.
6. Étudier la faisabilité d'une certification « PME Cyber-Sûre », piste évoquée avec l'encadrant.

Conclusion

Ce chapitre a présenté la conception et la réalisation de la plateforme : la démarche en jalons, du prototype Streamlit à l'application finale Pentascore ; une architecture qui sépare interface, API et moteur métier ; une méthodologie de scoring justifiée et explicable ; les fonctionnalités qui aident la PME à agir ; et une qualité logicielle vérifiée par plus de 350 tests. Les limites identifiées tracent les prochaines étapes vers un usage réel.

Conclusion générale et perspectives

Ce stage de Projet de Fin d'Année, réalisé sur sept semaines (15 juillet – 31 août 2026) au sein du CMRPI – Espace Maroc Cyberconfiance, a porté sur la conception et le développement d'une plateforme d'auto-évaluation de la maturité cybersécurité destinée aux PME marocaines. Au terme de ce travail, je peux dresser le bilan suivant.

Bilan des réalisations :

- Une analyse des référentiels normatifs (guide CMRPI/AUSIM, ISO 27001, NIST CSF, loi 09-08) a permis de justifier académiquement une structure de questionnaire en 5 domaines et 25 questions.
- Une plateforme fonctionnelle a été conçue et développée, intégrant un questionnaire d'auto-évaluation, un moteur de scoring automatisé et reproductible, ainsi qu'un export de rapports personnalisés au format PDF. Validée d'abord sous forme de prototype Streamlit, elle a ensuite été reconstruite en application finale, Pentascore : interface React, API FastAPI, moteur Python et base SQLite, fonctionnant entièrement hors ligne.
- La qualité logicielle de la plateforme a été validée par 285 tests côté serveur, 71 tests côté interface et 13 parcours de bout en bout, 98 % de couverture de code et un pipeline d'intégration continue, avec une validation de la cohérence méthodologique sur trois profils fictifs de PME.
- La démarche a été menée en trois jalons itératifs, suivis d'un jalon de consolidation, avec un suivi hebdomadaire et une validation systématique par l'encadrant professionnel, le Dr. Rachid Abouettahir.

Compétences mobilisées : analyse de référentiels normatifs en cybersécurité, conception d'une méthodologie de scoring justifiée académiquement, développement full-stack (Python, FastAPI, React et TypeScript), mise en place de tests automatisés et d'un pipeline d'intégration continue, gestion de projet et communication avec un encadrant professionnel.

Perspectives :

1. Conduire un pilote avec de vraies PME, via le CMRPI et l'AUSIM, et comparer les résultats à l'avis d'un auditeur.

2. Demander des preuves (politique, capture) et proposer une évaluation accompagnée par le CMRPI.
3. Calibrer les poids et les seuils sur les données du pilote ; proposer une version arabe.
4. Déployer la plateforme en ligne, avec une base PostgreSQL.
5. Mettre en place un benchmarking sectoriel anonymisé entre PME et étudier la faisabilité d'une certification « PME Cyber-Sûre ».

Au-delà du livrable technique, ce stage illustre l'impact potentiel d'une telle plateforme pour sensibiliser les PME marocaines à leur maturité cybersécurité, en cohérence directe avec la mission du CMRPI.

Bibliographie

[1] CMRPI, *Rapport d'activités du CMRPI 2012–2019*, 2019. visité le 11 août 2026. adresse : https://drive.google.com/file/d/13kYvrx3myTKyj65XQT6CN9YO2rnRLj_T

[2] CMRPI, *Catalogue des formations du CMRPI 2012–2021*, 2021. visité le 11 août 2026. adresse : https://drive.google.com/file/d/1WVx08p5Aoqg6CNC-DCAoHgzeeU_j4eqJ

[3] CMRPI et AUSIM, *Guide des Bonnes Pratiques en Cybersécurité*, 2021. visité le 10 juill. 2026. adresse : https://ausimaroc.com/guide-des-bonnes-pratiques-cmrpi/

[4] J. DAWES, « Do data characteristics change according to the number of scale points used ? An experiment using 5-point, 7-point and 10-point scales, » *International Journal of Market Research*, t. 50, n° 1, p. 61-104, 2008.

[5] ESPACE MAROC CYBERCONFIANCE, *Rapport d'activités EMC 2021*, 2021. visité le 11 août 2026. adresse : https://drive.google.com/file/d/1wAwX0i-IDZ_S7lVc_YL8YL4LxskPew8s

[6] ESPACE MAROC CYBERCONFIANCE, *Rapport d'activités EMC 2023*, 2023. visité le 11 août 2026. adresse : https://drive.google.com/file/d/1U4_ozZS1rW1D7bblJOiJHyeXjEQFwFvA

[7] ESPACE MAROC CYBERCONFIANCE, *Rapport d'activités EMC 2024*, 2024. visité le 11 août 2026. adresse : https://drive.google.com/file/d/1ed6yv5yJATrFKbFA41S7-GSw0S0PhHrE

[8] ESPACE MAROC CYBERCONFIANCE, *Rapport statistique — Signalements EMC-Helpline 2021–2024*, 2024. visité le 11 août 2026. adresse : https://drive.google.com/file/d/1A1Aey5OiXd5YcF2JJ8Xv92mWX9wuUWvG

[9] W. S. HUMPHREY, *Managing the Software Process*. Reading, Massachusetts : Addison-Wesley, 1989.

[10] INTERNATIONAL ORGANIZATION FOR STANDARDIZATION, *ISO/IEC 27001 :2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements*, 2022. visité le 20 août 2026. adresse : https://www.iso.org/standard/27001

[11] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY, *The NIST Cybersecurity Framework (CSF) 2.0*, 2024. visité le 20 août 2026. adresse : https://www.nist.gov/cyberframework

[12] REPORTLAB, *ReportLab PDF Library — Documentation*, 2024. visité le 15 août 2026. adresse : https://www.reportlab.com/

[13] ROYAUME DU MAROC, *Loi n° 09-08 relative à la protection des personnes physiques à l'égard du traitement des données à caractère personnel*, Dahir n° 1-09-15 du 22 safar 1430 (18 février 2009), Bulletin officiel n° 5714 du 5 mars 2009, 2009.

[14] STREAMLIT INC., *Streamlit — A faster way to build and share data apps*, 2024. visité le 15 juill. 2026. adresse : https://streamlit.io/

Annexes

Annexe A : Guide d'installation

A.1 Prérequis

- Python 3.12 ou supérieur ;
- Node.js 22 ou supérieur (pour compiler l'interface) ;
- pip (gestionnaire de paquets Python) ;
- git.

A.2 Étapes d'installation

```
# 1. Cloner le repository
git clone https://github.com/YOUSSEFKARROUM/PFA_CRMPI.git cmrpi-platform
cd cmrpi-platform

# 2. Creer un environnement virtuel (recommande)
python3 -m venv venv
source venv/bin/activate      # Windows : venv\Scripts\activate

# 3. Installer les dependances
pip install -r requirements.txt
pip install -r requirements-dev.txt   # pour les tests et le lint

# 4. Compiler l'interface React
cd frontend && npm ci && npm run build && cd ..

# 5. Lancer l'application (la base app.db est creee au demarrage)
uvicorn api.main:app --port 8000
# -> disponible sur http://localhost:8000

# 6. Verifier l'installation (optionnel)
pytest --cov=src --cov=api          # -> "285 passed" attendu
cd frontend && npm run test:coverage && npm run test:e2e
```

Listing 2 – Installation et lancement de la plateforme

Au démarrage, l'application crée et alimente automatiquement la base ; le script `scripts/init_db.py` permet de le faire à la main. Il crée le fichier `app.db` à partir de `data/schema.sql`, puis charge les 25 questions (français/anglais et guidance) ainsi que les recommandations depuis le classeur Excel `data/recommendations/Recommendations_Database.xlsx`.

Annexe B : Schéma de la base de données

Le tableau B.1 détaille les colonnes des deux tables centrales du modèle, `pme` et `audit` ; le schéma complet des sept tables (`pme`, `domain`, `question`, `audit`, `audit_response`, `recommendation`, `audit_log`) est disponible dans `data/schema.sql` du dépôt.

TABLE B.1 – Colonnes de la table `pme`

Colonne	Type	Description
`id`	TEXT (UUID) PK	Identifiant unique
`email`	TEXT UNIQUE	Email de connexion
`password_hash`	TEXT	Mot de passe haché (bcrypt)
`name, sector`	TEXT	Nom de l'organisation, secteur d'activité
`created_at`	DATETIME	Horodatage de création

TABLE B.2 – Colonnes de la table `audit`

Colonne	Type	Description
`id`	TEXT (UUID) PK	Identifiant de l'audit
`pme_id`	TEXT FK	PME concernée
`global_score`	REAL	Score global calculé (0–100)
`completed_at`	DATETIME	Date de complétion (NULL si en cours)

Annexe C : Extrait du questionnaire (format JSON)

Les questions, leur texte d'aide et leurs traductions sont pilotées par les fichiers JSON du dossier `data/questions/`. L'extrait ci-dessous illustre le format retenu pour une question du domaine Gouvernance.

```
{
  "id": "q_gov_01",
  "domain_id": "dom_gov",
  "order": 1,
  "text": "Votre organisation dispose-t-elle d'une politique de securite
     formalisee ?",
  "options": [
    {"value": 1, "label": "Non"},
    {"value": 2, "label": "Partiellement"},
    {"value": 3, "label": "Approuvee (1-2 ans)"},
    {"value": 4, "label": "Approuvee + revue annuelle"},
    {"value": 5, "label": "Approuvee + revue + communiquee"}
  ]
}
```

Listing 3 – Extrait de `questions_fr.json`

Annexe D : Dépannage (extrait de la documentation technique)

Le tableau D.1 reprend les principaux incidents rencontrés au cours du développement, documentés à des fins de maintenabilité pour un futur développeur reprenant le projet.

TABLE D.1 – Foire aux questions – incidents rencontrés et solutions

Symptôme	Cause et solution
`pip install` échoue avec une erreur `pkg_resources` sous Python 3.12	Une ancienne version de `pandas` (2.0.3), pourtant inutilisée dans le code, était épinglée dans `requirements.txt` et ne s'installait pas sur Python 3.12. Retirée du fichier.
Le score affiché ne change pas après modification du navigateur	Comportement voulu : le serveur ignore tout score envoyé par le client et recalcule toujours à partir des réponses brutes.
Prototype Streamlit : flake8 remontait des centaines de fausses erreurs sur `ui_components.py`	flake8 6.0.0 associé à pycodestyle 2.10 interprète mal le contenu CSS à l'intérieur des f-strings sur Python 3.12 (changement de tokenisation PEP 701). Le projet est contraint sur `flake8>=7.0`.
`app.db` corrompue ou incohérente	Supprimer le fichier et relancer l'initialisation : `rm app.db && python scripts/init_db.py`.
Le PDF généré affiche des caractères accentués incorrects	Vérifier l'encodage UTF-8 du classeur `Recommendations_Database.xlsx` ; incident similaire déjà rencontré et corrigé au Jalon 2.